Lab Assignment 1

SECURITY FUNDAMENTALS: IDENTIFYING THREATS, VULNERABILITIES, AND ATTACKS

Aim

To study real-world cybersecurity incidents and understand how threats, vulnerabilities, and attacks affect computer systems, networks, organizations, and individuals. To identify the causes, impacts, and preventive measures associated with different types of cyberattacks.

1. Introduction

Cybersecurity is the practice of protecting computers, networks, applications, and digital information from unauthorized access, damage, theft, and misuse. As organizations increasingly depend on digital technology, cyberattacks have become a major security concern.

Cybercriminals use different techniques, such as ransomware, malware, phishing, password attacks, software vulnerabilities, and supply chain attacks, to target individuals and organizations.

Understanding cybersecurity requires knowledge of three important concepts: threats, vulnerabilities, and attacks. A threat is a possible danger to a system. A vulnerability is a weakness that can be exploited by an attacker. An attack is an action performed to take advantage of that weakness.

Studying previous cybersecurity incidents helps organizations understand how attacks happen, what damage they can cause, and how similar incidents can be prevented in the future.

2. Basic Security Concepts

Threat: A potential danger that can harm a computer system, network, or information. Examples include hackers, malware, ransomware, and insider threats.

Vulnerability: A weakness in software, hardware, network configuration, or security practices that attackers can exploit. Examples include outdated software, weak passwords, and improper access permissions.

Cyberattack: An intentional attempt to access, damage, steal, or disrupt digital systems and information.

Impact: The consequences of a cyberattack, such as financial loss, data theft, service interruption, or reputational damage.

Prevention: Security measures used to reduce the possibility of attacks, such as software updates, strong passwords, encryption, firewalls, and multi-factor authentication.

3. Case Studies of Major Cybersecurity Incidents

3.1 WannaCry Ransomware (2017)

Introduction:

WannaCry was a major ransomware attack that occurred on 12 May 2017. It spread across computers in many countries and affected hospitals, businesses, government organizations, and other institutions. The ransomware locked users out of their files by encrypting the data and demanded payment in Bitcoin to restore access.

Threat:

The main threat was ransomware malware that encrypted important files and prevented users from accessing their systems.

Vulnerability:

The attack exploited a weakness in the Server Message Block (SMBv1) protocol used by older Windows operating systems. Microsoft had already released a security update called MS17-010, but many computers had not installed it.

Attack Method:

The attackers used a technique known as EternalBlue to exploit the Windows SMB vulnerability. Once a computer was infected, WannaCry could automatically spread to other vulnerable computers connected to the same network. It displayed a ransom message demanding payment to recover encrypted files.

Impact:

The attack affected more than 200,000 computers across at least 100 countries. The UK's National Health Service (NHS) was seriously affected, resulting in cancelled appointments and disruption to medical services. The attack demonstrated how outdated software could create serious security problems.

NAO report+2

Prevention:

Organizations should regularly update operating systems, install security patches, disable outdated protocols such as SMBv1, maintain secure backups, and use antivirus and network monitoring tools.

Lesson Learned:

This incident showed that delaying software updates can expose entire organizations to ransomware attacks. Regular patching and backup management are essential for protecting important information.

3.2 Equifax Data Breach (2017)

Introduction:

Equifax is a major credit reporting company that stores personal and financial information about millions of people. In 2017, Equifax experienced a serious data breach in which attackers gained unauthorized access to sensitive customer information.

Threat:

The main threat was unauthorized access to confidential personal information, which could be used for identity theft and financial fraud.

Vulnerability:

The breach occurred because Equifax failed to install a security update for a known vulnerability in Apache Struts, a software framework used by its website. The vulnerability was identified as CVE-2017-5638. Although a patch was available, the affected system remained unpatched.

Attack Method:

Attackers exploited the unpatched Apache Struts vulnerability to enter Equifax's systems. After gaining access, they were able to explore internal databases and collect sensitive personal information.

Impact:

Approximately 147 million people were affected. The stolen information included names, dates of birth, Social Security numbers, addresses, and some payment card information. The breach resulted in legal action, financial penalties, and damage to the company's reputation.

Federal Trade Commission+2

Prevention:

Companies should install security patches immediately, perform regular vulnerability assessments, encrypt sensitive information, monitor database activity, and restrict access to confidential records.

Lesson Learned:

The Equifax incident demonstrated that even large organizations can experience serious attacks when they fail to manage known software vulnerabilities properly.

3.3 Mirai Botnet (2016)

Introduction:

Mirai was a malware program discovered in 2016 that infected Internet of Things (IoT) devices such as security cameras, routers, and digital video recorders. It converted these devices into a network of infected machines called a botnet. Attackers used this network to perform large-scale Distributed Denial of Service (DDoS) attacks.

Threat:

The main threat was the disruption of websites and online services by overwhelming them with large amounts of unwanted network traffic.

Vulnerability:

Many IoT devices had weak security because they used default usernames and passwords. Some devices also had outdated firmware and poor security configurations.

Attack Method:

Mirai searched for vulnerable internet-connected devices and attempted to access them using commonly used login credentials. After infection, the devices became part of a botnet controlled by attackers. The attackers then instructed the infected devices to send huge amounts of traffic towards selected websites and servers.

Impact:

In October 2016, a Mirai-powered DDoS attack targeted Dyn, a major DNS service provider. This caused several popular websites and online services, including Twitter, Netflix, Amazon,

and others, to become unavailable or difficult to access for several hours. The original Mirai botnet contained hundreds of thousands of compromised devices.

United States Department of Justice+2

Prevention:

IoT users should change default passwords, use strong authentication, update device firmware, disable unnecessary services, and avoid exposing devices directly to the internet.

Lesson Learned:

The Mirai incident showed that even small devices such as cameras and routers can become serious cybersecurity threats when they are not properly protected.

3.4 SolarWinds Supply Chain Attack (2020)

Introduction:

The SolarWinds cyberattack was a major supply chain attack discovered in December 2020. SolarWinds developed IT monitoring software called Orion, which was used by many government agencies and private organizations. Attackers compromised the software development and distribution process to insert malicious code into legitimate software updates.

Threat:

The main threat was unauthorized access to government and business networks through trusted software.

Vulnerability:

The attackers took advantage of weaknesses in the software development and update distribution process. Organizations trusted the official SolarWinds updates and installed them without knowing that they contained malicious code.

Attack Method:

Attackers inserted malicious code into the SolarWinds Orion software build process. The infected software updates were distributed to customers through normal update channels. After installation, the malicious code created a backdoor that allowed attackers to communicate with compromised systems and potentially access sensitive information.

Impact:

Approximately 18,000 customers downloaded potentially affected versions of the Orion software. However, only a much smaller number experienced further malicious activity. Several government agencies and private organizations were affected. The incident raised serious concerns about the security of software suppliers and trusted updates.

MITRE ATT&CK®+2

Prevention:

Organizations should verify software updates, monitor third-party software, secure development environments, use code-signing protections, and continuously monitor unusual network activity.

Lesson Learned:

The SolarWinds incident demonstrated that attackers can target software suppliers to reach many organizations at once. Therefore, cybersecurity must also include third-party and supply chain security.

3.5 Colonial Pipeline Cyberattack (2021)

Introduction:

Colonial Pipeline is a major fuel transportation company in the United States. In May 2021, it experienced a ransomware attack that affected its computer systems. The company temporarily stopped pipeline operations as a precaution while responding to the incident.

Threat:

The main threat was ransomware, which can encrypt organizational data and disrupt important business operations.

Vulnerability:

The incident was associated with compromised login credentials used to access the company's systems remotely. The attack highlighted the risks of weak account security and insufficient protection of remote access.

Attack Method:

The DarkSide ransomware group was responsible for the attack. After gaining unauthorized access to the company's network, the attackers deployed ransomware and demanded payment.

Colonial Pipeline temporarily shut down its operations to manage the security incident and reduce further risks.

Impact:

The attack disrupted fuel transportation across parts of the United States and caused fuel shortages, panic buying, and increased fuel prices in some areas. Colonial Pipeline also made a ransom payment in response to the incident. The FBI later confirmed that DarkSide ransomware was responsible.

FBI+1

Prevention:

Organizations should use multi-factor authentication, secure remote access, regularly update systems, maintain offline backups, and separate business IT networks from operational technology networks.

Lesson Learned:

This incident showed that cyberattacks against critical infrastructure can affect ordinary people and essential services. Strong cybersecurity is necessary to protect important facilities.

3.6 Twitter Bitcoin Scam (2020)

Introduction:

On 15 July 2020, Twitter experienced a major security incident in which attackers gained control of several high-profile accounts. These accounts belonged to politicians, celebrities, business leaders, and cryptocurrency companies. The attackers used the accounts to publish fraudulent Bitcoin messages.

Threat:

The main threat was social engineering and account takeover, which allowed attackers to misuse trusted social media accounts to deceive users.

Vulnerability:

The incident exposed weaknesses in employee security awareness and internal access controls. Attackers were able to gain access to Twitter's internal systems by manipulating employees.

Attack Method:

The attackers contacted Twitter employees and pretended to be members of the company's IT support team. They used social engineering techniques to obtain employee credentials and access internal tools. They then took control of high-profile accounts and posted messages asking people to send Bitcoin with a promise of receiving a larger amount in return.

Impact:

Several well-known Twitter accounts were compromised, and users were tricked into sending cryptocurrency. According to an investigation by the New York State Department of Financial Services, the attackers stole more than $118,000 worth of Bitcoin. The incident also damaged public trust in the platform.

Department of Financial Services

Prevention:

Organizations should provide employee security awareness training, use strong multi-factor authentication, restrict access to internal tools, and monitor unusual account activities.

Lesson Learned:

The Twitter incident demonstrated that human error and social engineering can be used to bypass security systems. Employees must be trained to identify suspicious requests and protect their login credentials.

3.7 Yahoo Data Breach (2013–2014)

Introduction:

Yahoo was one of the most popular internet companies, providing email, search, and other online services. Between 2013 and 2014, Yahoo experienced major cyberattacks in which attackers stole personal information associated with hundreds of millions of user accounts.

Threat:

The main threat was large-scale data theft involving personal information and account credentials.

Vulnerability:

The attackers gained unauthorized access to Yahoo's user database and account systems. Weaknesses in account security, credential protection, and security monitoring contributed to the seriousness of the incidents.

Attack Method:

Attackers gained access to Yahoo's systems and stole information from its user databases. The stolen information included names, email addresses, telephone numbers, dates of birth, hashed passwords, and security questions and answers.

Impact:

The 2013 breach affected approximately three billion Yahoo accounts, while the separate 2014 breach affected approximately 500 million accounts. The incidents exposed a huge amount of personal information and increased the risk of identity theft and unauthorized account access.

yahoodatabreachsettlement.com+2

Prevention:

Companies should protect user databases using strong encryption, secure password hashing, multi-factor authentication, regular security audits, and continuous monitoring of suspicious activities.

Lesson Learned:

The Yahoo incidents showed that large amounts of personal information can become vulnerable when database security and account protection are not properly maintained.

3.8 Uber Data Breach (2022)

Introduction:

In September 2022, Uber experienced a cybersecurity incident in which an attacker gained unauthorized access to its internal systems. The attacker accessed several internal tools and services, including Slack and other company resources. The incident highlighted the dangers of stolen employee credentials and social engineering.

Threat:

The main threat was unauthorized access to internal company systems through compromised employee accounts.

Vulnerability:

The attack involved stolen login credentials and weaknesses in the authentication process. The attacker repeatedly sent multi-factor authentication (MFA) approval requests to an employee until one request was accepted. This technique is commonly known as MFA fatigue.

Attack Method:

The attacker reportedly obtained a contractor's corporate password after the contractor's personal device was infected with malware. The attacker repeatedly attempted to log in and sent MFA approval requests. After one request was accepted, the attacker gained access to Uber's internal network and several employee accounts and tools.

Impact:

The attacker accessed internal systems and company information. Some internal services and tools were affected, and Uber had to investigate the incident and strengthen its security measures. The incident also raised concerns about employee account protection and authentication security.

Uber+1

Prevention:

Organizations should use phishing-resistant multi-factor authentication, strong and unique passwords, employee security training, access restrictions, and monitoring of unusual login attempts.

Lesson Learned:

The Uber incident showed that using MFA alone is not always enough. Employees must carefully verify authentication requests, and organizations should use stronger authentication methods to prevent unauthorized access.

3.9 Bangladesh Bank Heist (2016)

Introduction:

The Bangladesh Bank cyber heist was a major financial cybercrime that occurred in February 2016. Attackers targeted Bangladesh Bank, the central bank of Bangladesh, and attempted to steal money from its account maintained at the Federal Reserve Bank of New York. The incident involved unauthorized payment instructions through the SWIFT international banking messaging system.

Threat:

The main threat was financial theft through unauthorized access to banking systems and payment instructions.

Vulnerability:

The attackers took advantage of weaknesses in the bank's computer security, including compromised employee credentials and insufficient monitoring of unusual financial transactions. The incident also exposed weaknesses in the bank's internal security controls.

Attack Method:

Attackers gained access to Bangladesh Bank's computer network and compromised systems connected to its SWIFT payment operations. They used the stolen access to send fraudulent payment instructions requesting transfers to accounts in other countries. Some transactions were rejected, but five transactions were successfully processed.

Impact:

The attackers successfully transferred approximately 81 million US dollars to accounts in the Philippines. Several other attempted transfers were blocked. The incident caused major financial and reputational damage and raised concerns about cybersecurity in the international banking system. The Federal Reserve Bank of New York stated that there was no evidence its own systems had been compromised.

World Bank+1

Prevention:

Banks should use strong authentication, separate critical banking systems, monitor unusual transactions, restrict employee access, maintain secure backups, and introduce additional verification for large financial transfers.

Lesson Learned:

The Bangladesh Bank incident demonstrated that cyberattacks can directly affect financial institutions and cause huge monetary losses. Banks must combine technical security with strong financial monitoring and transaction verification.

3.10 MOVEit Transfer Vulnerability (2023)

Introduction:

MOVEit Transfer is a software application developed by Progress Software. It is used by organizations to securely transfer files between computers and users. In May 2023, a serious vulnerability was discovered in MOVEit Transfer, which was exploited by cybercriminals to steal confidential information from organizations.

Threat:

The main threat was unauthorized access to sensitive files and databases, resulting in large-scale data theft.

Vulnerability:

The main vulnerability was a SQL injection flaw identified as CVE-2023-34362. SQL injection occurs when an application does not properly handle user input, allowing attackers to interfere with database queries. This flaw allowed attackers to access the MOVEit Transfer database without proper authorization.

Attack Method:

The Clop cybercriminal group exploited the vulnerability in internet-facing MOVEit Transfer systems. They used the weakness to gain unauthorized access and deploy malicious web shells. These tools helped them access and steal confidential information stored in the affected systems.

Impact:

The attack affected many organizations that used MOVEit Transfer to exchange files. Sensitive information belonging to businesses, government organizations, educational institutions, and individuals was exposed. The incident demonstrated how a single software vulnerability could affect many organizations at the same time.

Critical Vulnerability in MOVEit Transfer+2

Prevention:

Organizations should immediately apply security patches, regularly scan applications for vulnerabilities, restrict access to file transfer systems, monitor database activity, and investigate suspicious access.

Lesson Learned:

The MOVEit incident showed that software vulnerabilities can create risks for many organizations that depend on the same application. Regular updates and vulnerability assessments are essential for maintaining software security.

4. Overall Findings

The study of these ten cybersecurity incidents provides several important observations about the security of computer systems and networks.

1. Importance of software updates: WannaCry and Equifax demonstrated that outdated software and unpatched vulnerabilities can allow attackers to enter computer systems.

2. Weak passwords and authentication: Mirai and Uber showed how weak login credentials and improper authentication practices can lead to unauthorized access.

3. Human error and social engineering: The Twitter and Uber incidents demonstrated that attackers can manipulate employees to gain access to confidential systems.

4. Importance of network security: The Colonial Pipeline and Mirai incidents showed that attacks against networks can interrupt essential services and affect large numbers of people.

5. Protection of personal information: The Equifax and Yahoo breaches highlighted the importance of protecting databases containing sensitive customer information.

6. Third-party security risks: SolarWinds and MOVEit demonstrated that vulnerabilities in software supplied by external companies can affect many organizations.

7. Financial security: The Bangladesh Bank incident showed that cybercriminals can target banking systems and cause significant financial losses.

These incidents show that cybersecurity requires continuous monitoring, regular security updates, strong authentication, employee awareness, and proper access control.

5. Conclusion

Cybersecurity plays an important role in protecting digital information, computer systems, and networks from different types of attacks. The ten incidents discussed in this assignment demonstrate how cybercriminals exploit weaknesses in technology, network configurations, software applications, and human behaviour to achieve their objectives.

Some attacks involve ransomware and malware, while others involve social engineering, data theft, unauthorized access, and financial fraud. These incidents also show that cyberattacks can affect not only individual users but also large companies, government organizations, hospitals, and financial institutions.

Organizations can reduce these risks by maintaining updated software, using strong passwords, enabling multi-factor authentication, encrypting sensitive information, maintaining regular backups, and training employees about cybersecurity threats.

Therefore, understanding threats, identifying vulnerabilities, and recognizing different attack methods are essential steps towards building a secure digital environment.